

Threat Intel in Telecoms (TTIS2024)

On June 11th-12th, HardenStance hosted the 2024 Telecom Threat Intelligence Summit (TTIS2024). This summary write-up includes links to the presentation recordings.

- Most presenters emphasized the challenges telcos face from vulnerabilities in legacy technologies and largely familiar cyber threat vectors. A few speakers championed using AI in cybersecurity but attackers have a head start in leveraging it.
- Several speakers pointed to the heightened threat from nation state threat actors, including in the form of DDoS and spyware attacks. A compelling case was made for the likelihood of Stuxnet-like attacks starting to be launched at scale from 2025.
- Great examples of threat intelligence sharing best practice and calls for broader and deeper collaboration were offset by speakers raising practical, human-level limitations and calls to 'know thyself' first as the basis for good use of threat intel.

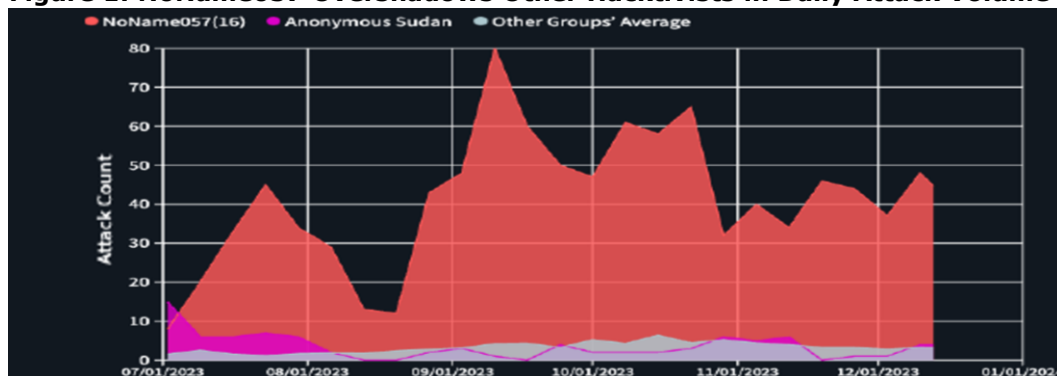
Human and technology fixes for DDoS threats

DDoS threats featured prominently again at this year's Telecom Threat Intelligence Summit. **Roland Dobbins, Principal Engineer, Netscout**, cited the following from the company's most recent DDoS threat report covering the second half of 2023:

- **The growth in hacktivism as a motivating factor driving DDoS attacks.** He cited 289 different hacktivist threat actors claiming to have attacked more than 6,843 targets across 139 industries and in 101 countries in the second half of 2023.
- **The gamification of DDoS attacks.** One advanced threat group, NoName057, has created a DDoS attack toolkit that anyone can download and get paid in crypto currency for participating in DDoS attacks, and then convert the reward into cash.
- **Improved obfuscation techniques** such as hiding and launching DDoS attacks from within cloud provider infrastructure.

Steinthor Bjarnasson, also a Principal Engineer with Netscout, elaborated on what the extrapolation of current DDoS threat trends will look like over the next few years. Steinthor said that attackers will need to get faster and more efficient at acquiring new devices because defenders are blocking them faster. As also stated by Autobahn

Figure 1: NoName057 Overshadows Other Hacktivists in Daily Attack Volume



Source: Netscout

This report was publicly released on July 16th, having been initially released to attendees immediately after TTIS 2024.

Tim argued that egress filtering using the BCP 38 standard to filter out spoofed traffic is relatively straightforward and low cost for telcos to implement.

Security's Karsten Nohl's (see page 5) Steinthor said that AI will increasingly be put to use for configuring and executing DDoS attacks. AI will increasingly be used to simplify the discovery of vulnerabilities and creating harder and harder-hitting botnets, he said.

Whereas the use of multiple DDoS threat vectors is mostly manual and time consuming today, Steinthor predicted that AI will increasingly be used to trigger threat vectors more economically. This will include saving time and money by monitoring the success of each threat vector one at a time and only automatically triggering the next one if the goal of the attack hasn't yet been achieved.

He predicted greater adoption of AI in the cause of DDoS defence as well. Whereas machine learning is mostly being used to analyze data reactively in DDoS defence these days, he pointed to increased adoption of AI to identify malicious activity and become more predictive about attacks. That will include anticipating what specific infrastructure is likely to be used in upcoming attacks against specific targets. This will enable faster, more pre-emptive, deployment of the right defensive strategies. In the 5G era, Steinthor also warned that telcos will need to get better at spotting malicious devices in their own networks to protect against the risk of their infrastructures being overwhelmed.

As well as guiding attendees on what to expect from the threat landscape and how best to leverage defensive tools, the Netscout speakers also advocated much greater collaboration between telcos to reduce the scope of the threat and cost burden imposed on the sector by DDoS threats. Their message on the need for better collaboration was taken up with real gusto in their talks by both Jaya Baloo, CISO with Rapid7, and **Tim Allsopp, Principal Technology Architect with Telus.**

"Be a 'Good Guy Greg', not a 'Scumbag Steve'"

Leveraging a bullet point in his slide deck urging ISP and transit providers to "be a Good Guy Greg, not a Scumbag Steve," Tim acknowledged the challenge faced by telco security operations teams. He called it "the Sisyphean task" of undertaking comprehensive cybersecurity hygiene. He cited the fact that telcos don't even control many customer endpoints like home routers as one reason for that. He also acknowledged that some aspects of cleaning up traffic before it's forwarded yields no direct benefit to the forwarding party. Further, he pointed out that in the case of transit providers that are paid by the packet, proper cyber hygiene can even be detrimental to these carriers' commercial interests.

Tim nevertheless called on the telco community to pull together as one on this because it's the right thing to do. He argued that egress filtering using the BCP 38 standard to filter out spoofed traffic is relatively straightforward and low cost for telcos to implement. It can substantially help reduce instances of one of the primary enablers of reflection/amplification DDoS attacks so everyone should be doing it.

Tim also made the case for leveraging DDoS traceback to "name and shame" poor behaviour by peering partners, arguing that this has been shown to reduce DDoS traffic. DDoS traceback involves using NetFlow to identify the interface from which bad traffic originates and trace that back to the telco or ISP that sent it. Offending peers can then be contacted, told of their transgression, and asked to implement the necessary measures. Tim called the principle "surprisingly simple. It's a community effort to use social capital to exert pressure on offending peers." He laughed and agreed with a suggestion that getting lots of telco security professionals to collectively mount this kind of peer pressure is a form of social reflection/amplification 'attack' on offenders.

Jaya Baloo, now CISO with Rapid7, shared her journey during her time as CISO of Dutch telco, KPN. She described how the need to get away from focusing on generic threat intel ingestion to a focus on enrichment and actionability in telco cyber security operations led to what she called an asset based approach to threat intelligence. This arrived at the importance of distinguishing a telco's vital services from its critical services. The former was defined as something internal that's part of a telco's unique

David Rogers said that the majority of threats the mobile operator community is seeing arises from advances in the threat landscape creating new vulnerabilities in legacy 2G and 3G mobile network standards.

service offerings; the latter was defined as things like an Internet connection or email service that any organization needs to conduct daily business operations. In her time at KPN, Jaya put that distinction at the core of arriving at the 'Maslowian pyramid of needs' developed internally for driving that telco's cyber threat intelligence practice.

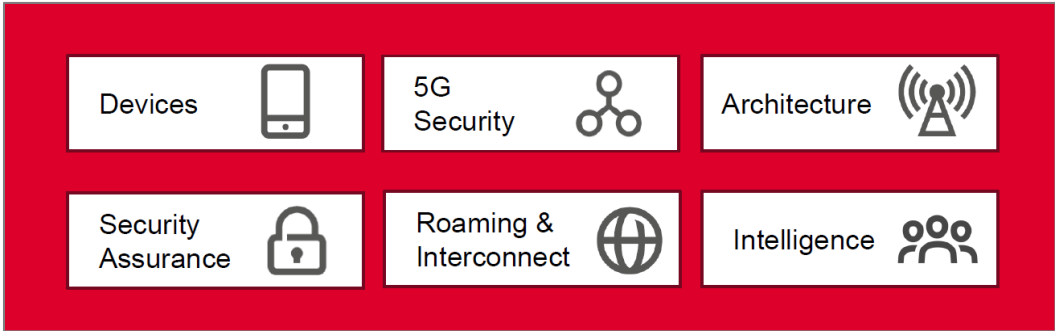
Echoing the Telus and Netscout speakers on DDoS threats from a telco perspective, Jaya brought together one of her core themes of the importance of understanding supply chain and service delivery interdependencies with the need for stronger decision-making, peer pressure and better collaboration. She said that while the telco community's understanding of interdependencies in cyber risk is evolving "there are still so many places where we don't understand those interdependencies. We certainly don't know about some of those single points of failure in our own infrastructure. They still come as a surprise which I find really quite disturbing."

Concluding with the imperative to "know thyself" first and foremost, Jaya warned against underestimating the threat of DDoS attacks that is still posed by the MIRAI botnet. "We're still seeing evolutions of MIRAI. They're still happening in the place which I think is most vulnerable - the home routers that telcos provide to their customers," she said. "We have a fundamental weakness here because we're not fully aware, we don't have a sub-component view to our processes and products. If we had that we would be in a much better position to respond far quicker. We're not really able to do that today."

David Rogers, Chair of the GSMA's Fraud and Security Group (FASG), gave an update on the group's activities, citing 1,500 active members now among fraud and security professionals representing the world's mobile operators. Referring to the 'Janus Problem' – a reference to the two-faced Roman God who looked both forward and backwards – David said that the majority of threats the mobile operator community is seeing arises from advances in the threat landscape that create new vulnerabilities in legacy 2G and 3G standards. "What we're seeing right now", he said "is a lot of issues that are related to legacy but new spins of that legacy." As examples, he cited new tools for sending unsolicited SMS messages and sending messages off-network. These are predominantly the threats manifesting themselves in the day-to-day operations of mobile networks, he said. "Sophisticated new stuff is a rarity," he added.

As shown in Figure 2, the FASG has 6 sub-groups. The Intelligence sub-group is disproportionately important, taking up around 50% of the agenda at plenary meetings. David also drew attention to the GSMA's Common Vulnerability Disclosure (CVD) programme which was put on a formal footing in 2017. This enables security researchers to privately disclose vulnerabilities to the mobile industry and delay disclosing them publicly until industry has had the opportunity to put a fix in place. David described this work as key and a "highly successful" element of threat intel sharing that protects billions of mobile users. "This is a massive service to the world", he said. "Imagine if any one of last year's 82 submissions had manifested itself in a mobile network. It could have been catastrophic in terms of costs to industry or to things like user privacy."

Figure 2: Key Sub-Groups of the GSMA's Fraud and Security Group (FASG)



Source: GSMA

FiGHT reuses the same principle as Mitre's ATT&CK Framework. Full convergence of the two is due with v3 release of FiGHT, planned for October this year.

David also shared brief updates on the GSMA's Mobile Threat Intelligence Framework (MoTIF) and the Telecommunications Information Sharing and Analysis Centre (T-ISAC). The latter now has over 190 members, of which 63% are mobile operators. He gave examples of members using the T-ISAC chat forum to rapidly share threat intelligence and mitigations with one another. He also pointed to non-determinism in standards as something that is "going to be a key topic for the future" Where protocols and standards are designed abstractly in the interests of encouraging innovation, he pointed to the risk of vulnerabilities arising from that non-determinism. That may be solved over time by automation but David said it will remain a live risk to be managed in the meantime.

Michaela Vanderveen, Principal 5G Security Architecture with Mitre, gave an update on the Mitre 5G Hierarchy of Threats (FiGHT) Framework for threat informed defence in risk management and security operations. Built from the ground up from an adversarial threat perspective, FiGHT is designed to be used by enterprise as well as mobile operator security operations teams. It allows security teams to see and understand threat actors; emulate their TTPs; develop the right security analytics; and assess and rate their own defences against those threats that represent the highest risk.

FiGHT reuses the same principle as Mitre's ATT&CK framework. Full convergence of the two is due with v3 release of FiGHT, planned for October this year. As well as convergence with ATT&CK, v3 will include information about what type of software adversaries are using; the campaigns of specific adversarial groups; what those adversarial groups are; and support for STIX, the language and serialization format for characterizing specific threats including a threat actor's motivations, capabilities and modus operandi. Having initially focused on threats to the mobile core, roaming and network slicing as well as virtualization and management threats, ORAN threats are being added to FiGHT. "That's because ORAN is very hot nowadays," Michaela said. "It's also fairly new and has a fair number of threats coming with it." Cloud threats are also starting to feature more prominently as 5G is deployed in the cloud.

A central theme of Michaela's talk was that so far, FiGHT has had to be built out largely leveraging predictive threat generation and without much real world 5G threat intel. So far, the inputs into FiGHT are based on theoretical 5G threats; threats actually observed in legacy mobile networks; those observed with mobile devices in enterprise networks; and those demonstrated in POC demos. She cited ENISA, GSMA and Nokia as examples of 5G and other mobile network threat intelligence that is used in FiGHT, along with papers from academia, other security researchers and other published reports.

Michaela appealed to the TTIS2024 audience to participate and share relevant mobile threat intelligence to grow and add value to FiGHT. She noted that threat sharing inputs from telcos into FiGHT are "saluted" rather than "practised" at this time, albeit one probable reason for that is the shortage of 5G Stand Alone (5G SA) networks being built out at scale.

Andrija Visic, Senior Programme Manager, ETIS shared some insights into the organization's work providing a trusted collaboration platform for telcos. Andrija was joined by co-presenters **Rolv Hauge, Business Continuity Manager, Telenor** and **Dominic Wood, Director of Security Governance and Assurance, BT**. They focused on the Information Security Working Group, one of 20 working groups within ETIS.

Recommending ETIS to other telcos, Rolv said that Telenor has been participating for a really long time and it's "really valuable". He shared the following examples:

- Development, approval and implementation of the guidelines on how to share sensitive information in physical and virtual conferences and platforms, within ETIS.
- Collaboration and dissemination of information, threat intelligence and best practices through self-hosted, secure instant messaging and MISP instances.
- Open, "politics-free" discussions, collaboration with suppliers and NGOs.

- Publication of the ETIS “Telco Security Landscape 2024” report.

Dominic added that BT has derived a lot of value from aligning with the ETIS-TNO Telco Security Benchmark which ETIS develops in partnership with TNO, a not for profit research organization based in The Netherlands. “The benchmark has been running for many years. All of us in the telco world want to know where we stand against our peers – we don’t just want to understand where we are but also the good things that other people are doing and that we can then replicate in our world.”

Defenders trail hackers in adopting AI but potential gains are bigger

Karsten Nohl, Managing Director of Autobahn Security boiled down his opportunity and risk assessment of Artificial Intelligence (AI) into two risks and one opportunity.

Two primary risks...

1. **Companies will be easier to hack arising from their own use of AI.** He pointed to how deploying AI in internal IT environments risks creating new holes in an organization’s cybersecurity posture. An example he gave is the potential to reverse engineer chatbots which rely on access to an organization’s data. This can expose more of an organization’s data than it wants exposed.
2. **All companies will be easier to hack because of hackers using AI.** Karsten cited auto-completion of phishing emails. Using the example of Japanese, he warned that phishing in languages that have yet to be widely used in phishing campaigns will catch native speakers of those languages unaware. AI-assisted malware creation at scale is another use case for hackers, together with tools like Chat GPT to identify vulnerabilities and calculate paths to successful attacks.

...and one primary opportunity:

3. **Companies will be harder to hack because of their defensive use of AI.** Karsten pointed to auto complete or pattern matching as promising huge gains for defenders. Cybersecurity teams have much more to gain than hackers, he said, because most cybersecurity work is routine and repeatable whereas most of what a hacker does requires expertise. Efficiency gains from using AI are maybe 5% on the attacker side but maybe 80-90% on the defender side, he said. “This is nowhere more so than in telcos, where we are looking at ginormous piles of data with a very, very occasional needle hiding in it.” Only then does the work get interesting for security operations, he said. “And how often does that happen? Maybe a couple of times per year or something like that.”

Karsten stated that these 3 opportunities and risks play out simultaneously. How an organization fares in terms of the net gain or loss it reaps depends on how well they avoid making themselves vulnerable from their own insecure use of AI on the one hand, and the use they make of AI-assisted defensive tools on the other. As a pragmatist, Karsten stated that “restrictions kill innovation but do you know what else kills innovation? Hacking! The best we as cybersecurity professionals can do is be a moderator between the two.” Importantly, he concluded that “there is a net positive if we play our cards right.”

He did sound an important cautionary note, arguing that there is currently greater momentum on the risk side of the equation. Specifically, the roll out of poorly secured AI deployments and of AI for hacking is happening at a faster pace than the adoption of AI in defensive cyber operations. At this point, he questioned the value of EDR or SIEM solutions being fed with prompts rather than commands. Practically speaking, he said, it doesn’t render these tools any easier to use for non-specialists who won’t understand the output. “It’s been a year already with Open AI for hacker innovation so I, for one, am getting impatient on the defence side. I want to see those tools that give us the 80% leverage [but] almost all of this potential on the defence side is coming down the road.”

Once vendors publicly announce there is a vulnerability, Jonas said that these days it usually takes less than 5 days before hackers start targeting them.

Jonas Walker, Director of Threat Intel, EMEA and APAC, for Fortinet shared the company's view of the threat landscape and some of the ways it is working with partners to bear down on cybercrime. Noting that the vast majority of cyber-attacks are still financially motivated – sabotage, espionage and control-motivated attacks are way behind as a share of the motivation among all attacks – Jonas noted growing convergence across previously distinct groups and motivations.

"These days it can be really hard from an attribution point of view to say whether something is a cybercrime or nation state group", he said. "Even cybercrime groups have become very sophisticated, very well-funded. They have access to a lot of money, they have their own zero days, or they even invest a lot of resources to find their own zero days. This is something we used to see only from nation state threat groups."

Referring to extracts from Fortinet's latest threat landscape report, Jonas said that the time it takes for new vulnerabilities to start to be exploited has "drastically reduced". Once vendors publicly announce there is a vulnerability, he said that these days it usually takes less than 5 days before hackers start targeting them. Of all the different use cases for deploying private 5G networks, Jonas also noted that manufacturing is the one that Fortinet is seeing being most targeted by threat actors.

Jonas also pointed to the work of the Cybercrime Atlas, hosted by the World Economic Forum (WEF). Fortinet is a lead partner in this alongside Microsoft, Santander and Paypal. Fortinet brings its wealth of telemetry and other threat insights alongside highly complimentary intelligence from Microsoft and the two financial services giants. He talked about the potential the Cybercrime Atlas has to disrupt the "huge choke points" in the cybercrime ecosystem, such as the shared technical and financial infrastructure that many of the threat groups use. The group's activity is centred on the four steps of mapping, disrupting, and deterring these behaviours of the cybercrime ecosystem and then expanding access to the resulting intelligence throughout the cyber security ecosystem. The Cybercrime Atlas is a little over 18 months old so Jonas encouraged industry to join and help it to scale up and out.

Michael Daniel, President and CEO of the Cyber Threat Alliance, addressed the important subject of how the cybersecurity community as a whole communicates cyber threat intelligence to non-technical stakeholders in an organization. He addressed the tendency for cyber professionals to do a poor job of translating cyber threat data into compelling calls to implement specific actions by these stakeholders.

"One of the challenges we have in our industry", he said "is that we frequently talk to non-experts like they're idiots. And assume that if you don't understand cybersecurity and all the technical nuances, then you're dumb. That's very off-putting. We don't like it when our doctor talks to us like we're idiots - why would we think our consumers and partners want to be spoken to like that?". Michael guided telecom sector threat intel professionals to tailor their findings to 3 stakeholder requirements:

- Be consumable by the specific organization.
- Be available in digestible units.
- Be sorted by the sender.

To illustrate the problem of organizations declining to share threat information in a way that would best benefit them and their peers, Michael invoked a pertinent saying of his Grandmother's: "you can try to teach a pig to sing but it will mostly frustrate you and annoy the pig." Once initial threat sharing connections are made, he said, it doesn't necessarily follow that organizations will necessarily benefit much from those connections at the outset, let alone over the longer term. For threat sharing to work effectively requires trust, money, time and attention. "You need all four of those factors in a sharing arrangement for it to actually work. If you don't have those, the sharing activity will either fade away or cease to be relevant."

In the UK Ofcom relies on seven sources of threat intelligence

Gerry McQuaid, Director of Telecom and Internet Security for Ofcom gave a talk describing Ofcom's use of threat intelligence, a term he used to embrace a wide variety of different physical world threats to telecom networks as well as cyber threats. Gerry emphasised that a regulator's requirements in terms of the actionability of threat intel are fundamentally different to those of an operator. A regulator is focused more on high level strategic implications of a given threat for a broad range of stakeholders rather than detailed operational solutions.

He said that Ofcom's 3 key areas of interest are: (1) generic cyber threats with a potential high impact on the telecom sector, whether from a vulnerability in a library impacting vendors throughout the Internet ecosystem or a specific problem with just one product in a key telecom vendor's portfolio (2) anything to do with signaling threats - who the threat actors are, what TTPs they're using; the effectiveness or otherwise of different security controls (3) insights into BGP and DNS security threats.

Gerry's list of the 7 different types of threat intelligence sources Ofcom relies on – and his comments on them – make for interesting reading for peers in other regulators and other industry stakeholders:

- 1) **National technical authorities.** These include the UK's National Cyber Security Centre (NCSC) with whom Gerry said Ofcom liaises hourly, and the National Protective Security Authority (NPSA).
- 2) **Law enforcement/the police.** These share useful incident reports and information.
- 3) **Other regulatory authorities.** Regulators covering other sectors of industry.
- 4) **Vendors.** Gerry noted "quite a shift" in the attitude of vendors over the last three or four years in terms of how able and willing many of them now are to talk about the potential impact of a risk is in relation to their products and their approach to mitigating it. He called this a "notable and positive" change, albeit one which isn't universally adhered to.
- 5) **Industry Associations** such as the GSMA and ASIS
- 6) **Commercially available threat intel tools and feeds.** Gerry stressed that even a regulator like Ofcom has a much smaller budget for investing in threat intelligence compared with commercial stakeholders. Ofcom makes use of freely available tools, some of which he said are "very good". Ofcom also invests in access to some threat intel feeds and commissions specific reports as needed.
- 7) **UK telecom operators.** One UK telco has started voluntarily sharing threat intelligence that falls below the threshold against which it is legally obliged to share data with Ofcom. The threat intel shared fully protects customer confidentiality and is triaged to arrive at high level conclusions that help Ofcom better differentiate those incidents it needs to be concerned about from those it doesn't. Gerry called this "a really good indicator" of threat-sharing maturity on the part of this telco and alluded to one or two other operators he hopes will enter into this kind of partnership before long.

Pepijn Kok, CISO of AIS, Thailand's largest mobile operator, gave a detailed account of his team's response to two separate outbreaks of fake base station or IMS catcher fraud in his market. The first began at the end of 2022 when one of the largest banks in Thailand reported to AIS that customers were receiving malicious text messages purporting to be from the bank. These contained malicious links which users interacted with, leading to fraudulent financial transactions amounting to a total of \$3.5 million.

AIS investigated the incidents, comparing them against familiar smishing threats and concluded after a couple of days that the SMS messages used weren't actual SMS messages. The investigation then concluded that these were false base station attacks. AIS found evidence that scammers were disconnecting customers' 4G connections and reconnecting them to the less secure 2G network. They were then leveraging the control this gave them over handsets to insert the rogue messages.

Using the phones of affected customers, AIS was able to determine that the timing and location of incidents meant the scammers had to be working from a moving vehicle.

Using the phones of affected customers, AIS was able to determine that the timing and location of incidents meant the scammers had to be working from a moving vehicle. AIS engaged the Thai police who used CCTV footage and AIS' network records and capabilities to arrest six individuals for using false base stations hosted in their cars to carry out this campaign.

A second wave of false base station scams

After the success in enabling these arrests, Pepijn reported that several months went by without any further incidents. Then in April this year, AIS saw a second wave of false base station scams. This time they targeted AIS directly (pointing customers to a fake AIS payment site) and used slightly different techniques. This time the scammers were walking around shopping malls with fake base stations using directional antennae in their backpacks. Pepijn shared with some pride that from the time AIS became aware of this second wave of scams to the police apprehending and arresting the suspects in a shopping mall took around 36 hours. Arising from this experience, he shared that Thailand's banks no longer embed links in SMS messages. As well as having the right investigative capabilities in place, and partnering local law enforcement, Pepijn also stressed the importance of strong communications and awareness-raising around fraud risk to mobile users. Key to that, he said, was AIS supporting media reporting of the arrests so as to get the word out to consumers (and by implication, to scammers too).

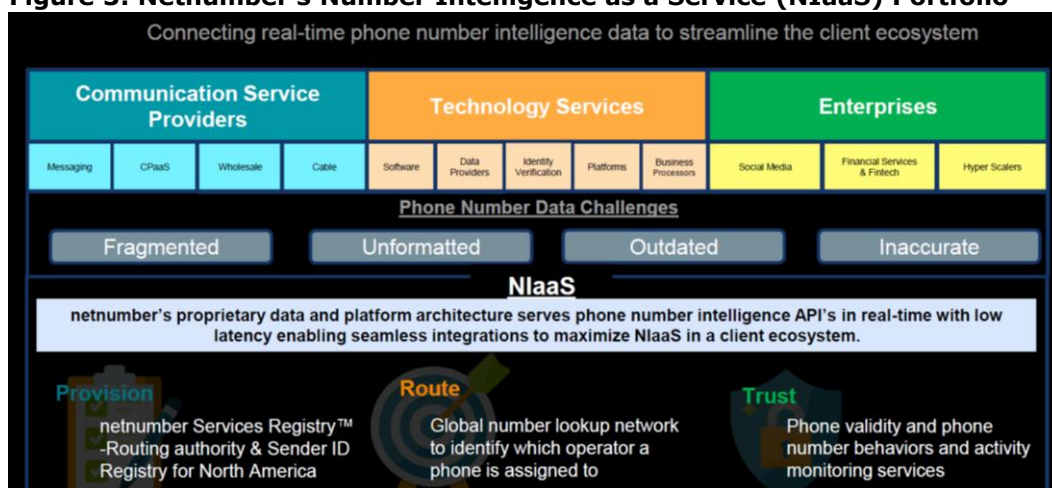
Jelte Jansons, Director of Product Management, Enea, addressed many well-known control plane threats including those using SS7 and Diameter. He spent a lot of his talk on the abuse of Global Title (GT) leasing in inter-carrier routing of signaling messages and how to prevent it. A key aim of his talk was to dispel the myth, as he sees it, that the networks typically used in these types of attacks are invariably located in remote, little-known, remote parts of the world because those networks are somehow more vulnerable to abuse. He pointed to many attacks seen in 2022 and 2023 that used European GTs. He referred to one global SS7 attack in July 2023 that used GTs from Finland, Lithuania, Estonia, Latvia, Croatia, Slovenia, Denmark and Poland.

Jelte gave the specific example of one specific threat actor, Switzerland-based Fink Telecom Services, and its work as a surveillance broker or provider of 'surveillance as a service' working with Israeli spyware firms. Having been watching Fink since 2017, Enea observed Fink taking part in a major global attack in 2023. Following a lot of (no doubt unwelcome) media attention on the company once its involvement in these attacks was exposed, Jelte said that Enea then observed Fink go quiet for a period. The threat actor then emerged again in early 2024 using GTs in Belgium, Cambodia, Latvia, Estonia, UK, Peru, Poland, Nigeria and the UK.

As a starting point for preventing the use of GTs in these campaigns, Jelte made the case for adopting the GSMA's Global Title Leasing Code of Conduct, citing Deutsche Telekom as one of the first telecom operators to publicly commit to adopting it. He cited the GSMA code's central position that there is no reason – no technical justification – why GTs should ever need to be leased.

As large scale adoption of the code of conduct is going to take time, Jelte pointed to additional layers of a solution that are needed. He cited access to up to date signaling threat intelligence to identify threats, as well as optimal configuration of signaling firewalls to ensure protection is dynamically mapped to those threats.

Figure 3: Netnumber's Number Intelligence as a Service (NlaaS) Portfolio



Source: Netnumber

Bradley, Greer, VP Marketing, Netnumber, described his company's Number Intelligence as a Service (NlaaS) solution for telcos, Communications Platform as a Service (CPaaS) providers and enterprise or business brands that integrate communications services into their own customer communications.

Netnumber integrates, normalizes, curates and updates hundreds of sets of phone number data with a footprint of 2.9 billion phone numbers from around the world to serve optimized provisioning, routing and fraud prevention use cases across voice and text services. As Bradley put it, the company is "the go-to source for anything you need to know about a phone number."

Number intelligence for fraud prevention

In the context of the Telecom Threat Intelligence Summit, Bradley dedicated a lot of his talk to articulating the company's value proposition for fraud prevention use cases, touching on subscription and provisioning fraud, unauthorized VOIP calling; platform misuse and abuse; service plan misconduct; phishing and smishing fraud; sender ID and CLI spoofing; as well as port out fraud.

Nick Palmer, Senior Solutions and Customer Engineer with Censys, presented his company as laying claim to putting "the largest Internet scanning infrastructure in the world" at the disposal of its customers, including some telcos. He qualified this in terms of being able to scan the entire Internet every single day – "all of the 65,000 ports, all of the services, all the virtualized hosts and with automatic protocol detection across all the ports." This includes even non-standard ports, he emphasized. So if a customer is running RDP on port 75, they still have visibility of that as RDP. Censys also owns what Nick said is the world's largest X509 certificate database – a 20 terabyte certificate database growing at 20 gigabytes per day.

Nick pointed to three primary attack surface management use cases that the Censys scanning infrastructure can be applied to:

1. **Assessing third party suppliers.** Customers can use it to get a true picture of a supplier's external attack surface – its' appetite for fixing things as well as the status of its infrastructure – as a way of verifying its' claims. Nick gave an example of yielding information on the number of certificate issuers a supplier is dependent on; whether those certs are self-signed or generated by other providers; and whether any of those certs are showing up on criminal infrastructure.

Netnumber integrates, normalizes, curates and updates hundreds of sets of phone number data with a footprint of 2.9 billion phone numbers from around the world.

2. **Assessing the organization's own infrastructure.** Drawing attention to the upstream as well as the downstream use cases of attack surface management, Nick pointed to the context of regulations such as DORA governing the financial services industry. Telcos need to ensure that the services they offer to high value customers like those in the financial services industry have the appropriate level of security embedded in them. "You can make yourself more marketable and more profitable by doing this correctly", he said.

He shared what sounded like a compelling example of one large Censys customer – what he called "one of the largest hardware suppliers in the world, a vendor which I have no doubt all the telcos attending this event will own infrastructure from." This large vendor uses Censys to scan the external-facing attack surfaces of all the companies it acquires. Nick said that about 10% of these acquisition targets "don't make the cut based on their external attack surface."

3. **Early visibility into 'celebrity vulnerabilities.'** When a high profile, high severity vulnerability is announced, Censys will notify customers if they have a vulnerable device in their attack surface within 24 hours – independent of that customer's own inventory. "We can help you get to a compromised device 6 or 7 days before an attacker can exploit it", Nick concluded.

Defending Ukraine and Poland against Russian cyber threats

Irek Tarnowski, Cyber Threat Analyst with Orange Polska, gave a breakdown of cyber threats that Poland and Ukraine have been seeing and which have been attributed to Russia, including a very large volume of attacks on these two countries' telecom sectors. During 2023, Irek stated that a team of Russian military hackers affiliated to the GRU, Russia's Chief Intelligence Office, carried out 68 cyber attacks on Ukraine's telecom sector alone. Of these, 10 were successful in having some kind of impact.

Irek also gave a step-by -step breakdown of the TTPs used in attacks by the Russian Sandworm threat group on 11 different ISPs between May and September 2023. Noting that the attacks relied largely on commonly available attack tools rather than being very sophisticated, he stated that internet access, hosting and email services of these ISPs were all impacted. "Very often we think that Advanced Persistent Threat (APT) groups use very sophisticated tools", he said "but in these cases they were able to use very simple tools." From Irek's comments it was clear that the absence of proper backup procedures in some cases made recovery harder for some of these ISPs.

Inevitably, Irek cited the devastating attack on Kyivstar in 2023. This is widely reported as having basically wiped out the operator's core network, taking it out of service for millions of Ukrainians for days. He relayed that the attack started with a compromised email account of a Kyivstar employee creating an initial pathway into the operator's core network. He noted that the attack formed a part of Russia's hybrid war on Ukraine. Missile attacks on Kiev were timed to coincide with triggering the huge Kyivstar outage. Irek put the cost of this attack to Kyivstar at \$100 million in revenue losses.

Whilst he said the threat intel sharing between Orange Polska and its Ukrainian partners is very good and well advanced, Irek implied that they were not as well developed with other countries in the region or further afield. "Sharing cyber threat intelligence information is not easy", he said. "Not all companies want to share and collaborate. The most important thing is direct contact and trust at the operational level. We have that with some partners but very often it's not official or through a formal agreement. It's more based on trust between people."

Nelson stated that generic EDR systems also create additional security challenges in the real-time, high availability, services environment of 5G.

Corradino Corradi, General Manager, Information Security Architecture and Technology, MTN reports to MTN Group's CISO. One of the main highlights of his talk was a discussion of the organization of cyber defences in terms of people and technology in MTN and how the gathering, processing and use of threat intel is done within that.

While the use of threat intel within MTN goes back many years, a new unit dedicated to threat intelligence and threat hunting was only created within the group three or four years ago. Since then, this unit has enjoyed the status of one of four dedicated units alongside three others dedicated to 24/7 security operations, vulnerability assessments and penetration testing.

Echoing the "know thyself" themes of Jaya Balloo and Michael Daniel, one of the core functions of MTN's threat intel team is nurturing a granular understanding of different stakeholder groups within the organization and tailoring threat intelligence reports to each group with a different balance of strategic, operational and tactical threat intel.

Internal sources, external sources and human sources

Corradino shared that what his company's threat intelligence team ingests can be grouped into 3 primary sources. These are internal sources (which are pulled from within the organization's internal and external networks); external technical sources (such as vulnerability assessments on Internet-facing parts of MTN's infrastructure and services); and what he called human sources (open source intelligence or OSINT such as intel that is derived from the dark web as well as social media posts that are considered to pose a risk to MTN's reputation).

Within the security organization, MTN is shifting data storage and processing from relational databases to linear databases. The company is also piloting Gen AI as a means of enabling higher efficiency in the work of SOC analysts. In the work of analyzing threat intelligence, Corradino said that the "true differentiator lies in understanding threat actor motivations and why we are targeted", which is done leveraging the MITRE ATT&CK Framework as a baseline. Consistent with this, he said this is done according to a risk based approach which focuses on "the real motivations and not so much on technology."

Nelson Silva, Product Manager, Nokia spoke to the need for a specialized approach to endpoint security in 5G. In particular, he articulated the case for why Endpoint Detection and Response (EDR) solutions that are optimized for protecting enterprise IT environments "fall short" of protecting the Network Functions (NFs) in a cloud native 5G network. More than that, Nelson stated that generic EDR systems also create additional security challenges in the real-time, high availability, services environment of 5G.

Whereas IT breaches typically result in financial losses or data theft, Nelson stressed that telco breaches can lead to eavesdropping, or to network and service outages and degradations that all organizations connected to those networks and services are reliant on to function.

Nelson listed the weaknesses of enterprise IT-optimized EDR solutions in a telco environment as follows:

- Regulatory standards including HIPAA, PCI, DSS.
- Protects the data but is invasive.
- More lenient hardware and OS dependencies.

He contrasted this with the strengths of a telco-optimized solution:

- No impact on ultra-low-latency and high-availability services.
- Complies with telco regulatory standards (3GPP, NIST).
- Keeps the network data within the CSP's premises.

In making the case for a multi-layered approach for telcos that embraces the network layer as well as the endpoint, Nelson pointed to the specific example of the recently discovered 'GTPDoor', a Linux backdoor designed to exploit GTP and GRX connectivity between mobile operators. It's important to be able to detect attacks like this in any of all its multiple phases as they unfold, he said. Hence "it's not sufficient for a telco to monitor the endpoint individually. We need to be able to monitor the whole network, the whole of the traffic, to be able to map blind spots. These could be agent-less nodes or appliances or other nodes that might create these blind spots in the network."

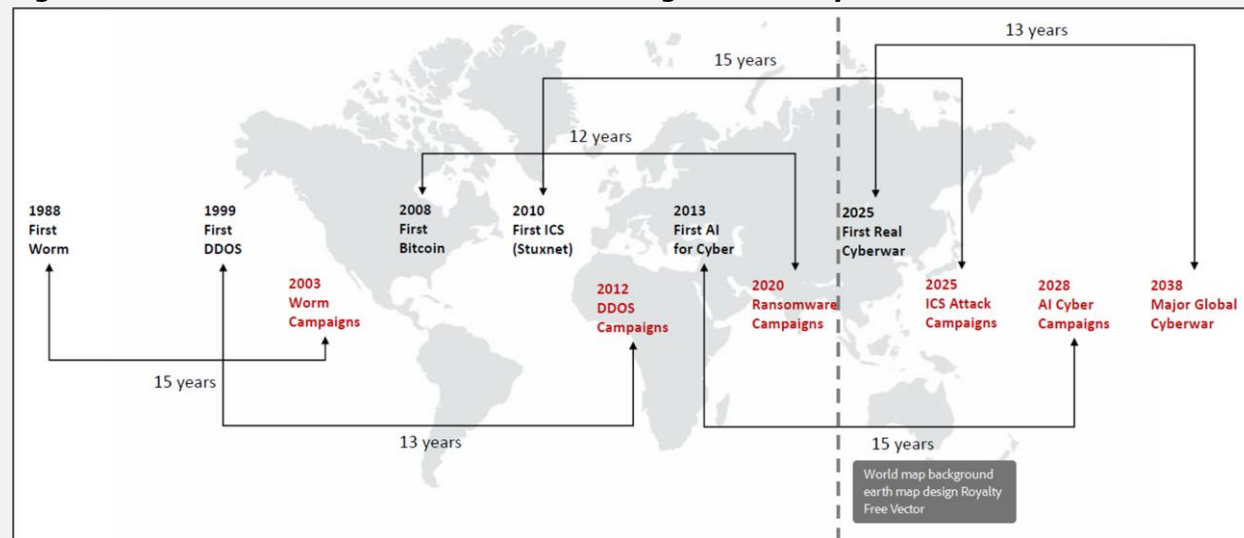
Stuxnet-like incidents should be expected at scale from next year

Former AT&T Chief Security Officer, **Ed Amoroso, now CEO of TAG Infosphere**, shared his assessment of a pattern he has observed in more than three decades as a cybersecurity professional. As shown in **Figure 4**, the cycle starts with a major new cyber threat being seen for the very first time. With very little variation, that threat isn't seen much or at all for many years. Then, according to a pattern that Ed said repeats itself time and time again, this threat beings to manifest itself at scale some 12-15 years after it was first seen.

The observation of this pattern led Ed to share with the TTIS audience that following the deployment of Stuxnet to jam up the workings of a sizable number of Iran's nuclear centrifuges in 2010, the first of a wave of outbreaks of Stuxnet-like incidents impacting industrial control systems should be expected during the course of next year. "If you think we're not going to see Stuxnet at scale, I think you're wrong", he said. "We're going to see Stuxnet at scale soon because the model predicts it."

Worse, Ed predicted what he called "the first real cyber war" next year which he defined as "trying to kill at scale with cyber." Assuming that transpires, he said that that then points to the first global cyber war in 2038 where "nation states will try to establish superiority and not worry about people getting killed in the meantime". Ed's talk may not have been uplifting but it was compelling. On the upside, his talk did also offer good food for thought on the existence of such patterns. It should also provoke further thinking on what defenders can do to affect and manage those threat trends to their advantage.

Figure 4: Clear Historical Attack Patterns Leading to Global Cyber War



Source: TAG Infosphere

Cyber risk and cyber risk management has to embrace the attack surface of partners and suppliers as much as the attack surface that an organization itself directly owns.

Jared Smith, Distinguished Engineer, Threat Research, Security Scorecard, shared his company's journey from being a cyber ratings provider to augmenting that with unique insights gleaned from an increasingly imaginative and proactive approach to collecting and applying threat intelligence. His starting point was to emphasize how cyber risk is becoming much more distributed. These days, cyber risk and cyber risk management has to embrace the attack surface of partners and suppliers as much as the attack surface that an organization itself directly owns, he said.

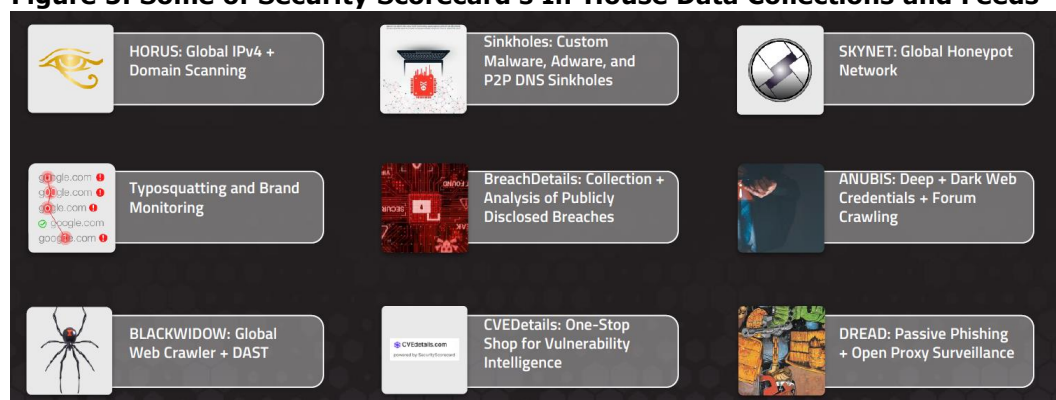
Most firms don't really know their own vendors, he went on, pointing out that things like reputation feeds can only tell you so much about a vendor's cybersecurity posture; they can't tell you as much as you need to know about how shadow IT and BYOD operates in practice in these organizations. In the case of telco customers, Jared said that Security Scorecard runs honeypots in mobile networks to identify exactly what is hitting their specific devices, their IPv4 and IPv6 addresses. "In telecoms, we often see threats that we don't see elsewhere in other parts of the ecosystem", he said.

As shown in **Figure 5**, Jared described the many different sources and tools that Security Scorecard's team of 20 dedicated cyber threat intelligence experts relies on to collect and curate cyber threat intelligence that is then tailored to the needs of unique customer sets. He said that from depending on third party feeds for 50% of its threat data years ago, 99% of it is now derived internally from the company's own scanning.

He cited a number of key proof-points for the capabilities of Security Scorecard's threat intelligence team to differentiate itself in the market. Among these are the following:

- **Identified a new Russian APT botnet in the opening hours of the Ukraine-Russia conflict and enabled the U.S Department of Homeland Security's 'Shields Up'.** The company rapidly deployed a honeypot in Kyiv to see if there was evidence of new Russian APT botnet activity complementing the kinetic strikes on Ukraine. The sensors found evidence of activity that none of Security Scorecard's other honeypots in other European countries had detected. This enabled the company to work with U.S and Ukrainian authorities to release the relevant IoCs to block the malicious traffic.
- **The company's threat intelligence powers the Security Operations Centre (SOC) for the largest ISP in Japan.** It is fed directly out of its streaming infrastructure to monitor bad reputation IPs and exposed vulnerable IPs on that customer's attack surface.
- **De-anonymized hackers behind T-Mobile incident in 2021 that exposed 37 million individuals' information.** This led to action to pursue prosecutions.

Figure 5: Some of Security Scorecard's In-House Data Collections and Feeds



Source: Security Scorecard

* "Threat Intel in Telecoms (TTIS2024)", Copyright: Patrick Donegan, HardenStance Ltd, 2024

View the TTIS2024 Event Recording

TTIS2024 was sponsored by [Netscout](#), [Enea](#), [Nokia](#), [Fortinet](#), [Censys](#), [Security Scorecard](#) and [Netnumber](#), as well as co-sponsored by [The Cyber Threat Alliance](#). You can view the full recordings of the two day event here:

Day 1: <https://www.youtube.com/watch?v=pMjeuQEx35E>

Day 2: <https://www.youtube.com/watch?v=ybVmJunuZSc>

Each speaker and the start-time of their talk in the video recording is listed here:

Day 1

- 0.00.00 Patrick Donegan, (Founder, Principal Analyst, HardenStance)
- 0.08.00 Pepijn Kok (CISO, AIS)
- 0.29.15 Karsten Nohl (Managing Director, Autobahn Security)
- 0.54.20 Roland Dobbins (Principal Engineer, NETSCOUT)
- 1.24.20 Jonas Walker (Director of Threat Intelligence, MEA & APAC, Fortinet)
- 1.46.00 Andrija Visic (Senior Programme Manager, ETIS)
- 2.11.06 Nelson Silva, (Cybersecurity Product Manager, Nokia)
- 2.36.15 Tim Allsopp (Principle Technology Architect, Telus)
- 3.04.00 Ed Amoroso (Founder & CEO, Tag Infosphere)
- 3.29.00 Michael Daniel (President and CEO, Cyber Threat Alliance – CTA)
- 3.51.28 Nick Palmer (Senior Solutions and Customer Engineer, Censys)

Day 2

- 0.00.00 Patrick Donegan (Founder, Principal Analyst, HardenStance)
- 0.06.45 Gerry McQuaid (Director of Telecoms & Internet Security, Ofcom)
- 0.30.05 Jelte Jansons (Director of Product Management, Enea)
- 0.53.58 Corradino Corradi (GM, Information Security Architecture, MTN Group)
- 1.29.28 Jaya Baloo (CISO, Rapid7)
- 1.56.10 David Rogers (Chair, GSMA's Fraud and Security Group – FASG)
- 2.20.46 Steinthor Bjarnasson (Principle Security Engineer, NETSCOUT)
- 2.42.11 Ireneusz Tarnowski (Cyber Threat Analyst, Orange Polska)
- 3.11.00 Bradley Greer (VP, Data Solutions & Product Marketing, Netnumber)
- 3.37.40 Michaela Vanderveen (Principal 5G Security Architect, MITRE)
- 3.59.10 Jared Smith (Distinguished Engineer, Threat Research, Security Scorecard)

More Information

- [NETSCOUT Threat Intelligence Report \(2H 2023\)](#)
- [The Censys "2023 State of the Internet" report](#)
- [Enea's "2024 Mobile Trends" Report](#)
- ["Netnumber's Unique NIaaS Portfolio" \(May 2024\)](#)
- [Fortinet's "Global Threat Landscape Report 2H 2023"](#)
- [Nokia's Threat Intelligence Report 2024](#)
- [Security Scorecard's "Security Ratings Methodology for Telcos, ISPs & Cloud Providers"](#)
- [The ETIS 'Telco Security Landscape 2024' report](#)

-
- [About Cyber Threat Alliance](#)
 - [GSMA's Mobile Threat Intelligence Framework \(MoTIF\) Principles v1.0 \(March 2024\)](#)
 - [GSMA's "Global Title Leasing Code of Conduct FS 52" March 2023](#)
 - ["Peer\(ing\) Pressure: Achieving Social Action at Scale in the Internet Infrastructure" \(Collier & Clayton, 2024\)](#)

HardenStance Reports

- ["Two-Sided Security for 5G Fixed Wireless Access" \(June 2024\)](#)
- ["MWC24: Taking Stock of Telco Security" \(March 2024\)](#)
- ["A Quantum-Safe Roadmap for Telcos" \(March 2024\)](#)
- ["Telco Security Takeaways from the NIS2 Directive" \(November 2023\)](#)
- ["Using Threat Intelligence in Telecoms \(TTIS2023\)"](#)
- ["RSA Survey on 'Barriers to Effective Use of Threat Intelligence" \(March 2023\)](#)
- ["Intelligence-Driven DDoS Defence" \(February 2023\)](#)
- ["Streamlining Telco SOC Operations" \(November 2022\)](#)
- ["Preparing for New Incident Reporting Requirements" \(November 2022\)](#)
- ["Tidal Cyber's Community Edition is GA" \(August 2022\)](#)
- ["Defending Telecoms against Nation State Cyber Threats" \(June 2022\)](#)

About HardenStance

HardenStance provides trusted research, analysis and insight in IT and telecom security. HardenStance is a leader in custom cyber security research and leading publisher of cyber security reports. HardenStance is also a strong advocate of industry collaboration in cyber security and is the organizer and host of the Telecom Threat Intelligence Summit. HardenStance openly supports the work of key industry associations, organizations and SDOs including NetSecOPEN, AMTSO, The GSM Association, OASIS, ETSI. The Cyber Threat Alliance. HardenStance is also a recognized Cyber Threat Alliance 'Champion'.

- [Register to receive public domain HardenStance reports when they're released](#)

HardenStance Disclaimer

HardenStance Ltd has used its best efforts in collecting and preparing this report. HardenStance Ltd does not warrant the accuracy, completeness, currentness, noninfringement, merchantability or fitness for a particular purpose of any material covered by this report.

HardenStance Ltd shall not be liable for losses or injury caused in whole or part by HardenStance Ltd's negligence or by contingencies beyond HardenStance Ltd's control in compiling, preparing or disseminating this report, or for any decision made or action taken by user of this report in reliance on such information, or for any consequential, special, indirect or similar damages (including lost profits), even if HardenStance Ltd was advised of the possibility of the same.

The user of this report agrees that there is zero liability of HardenStance Ltd and its employees arising out of any kind of legal claim (whether in contract, tort or otherwise) arising in relation to the contents of this report.